

AUDITORIA SEGURIDAD INFORMATICA - EJERCICIO PRACTICO

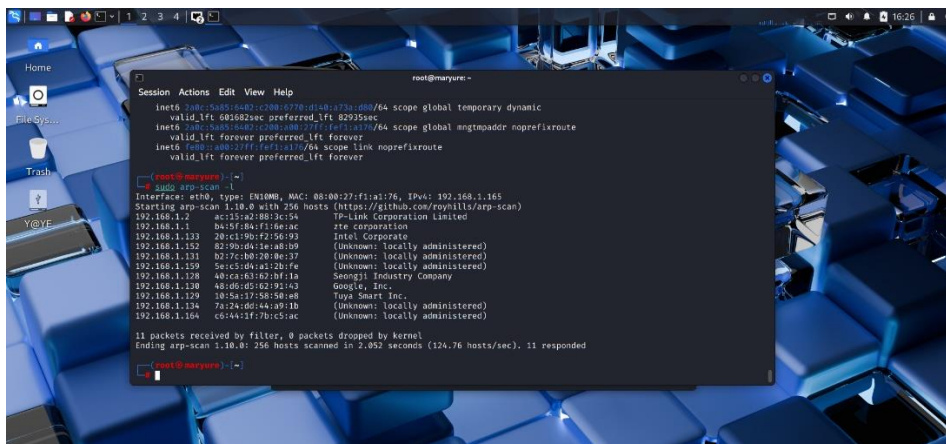
Equipo de práctica: Maryure Delgado, Karen Siles, Pablo Ferrer

Fase 0 - Reconocimiento de IP y revisión de red a revisar.

IP de trabajo: 192.168.1.165/24

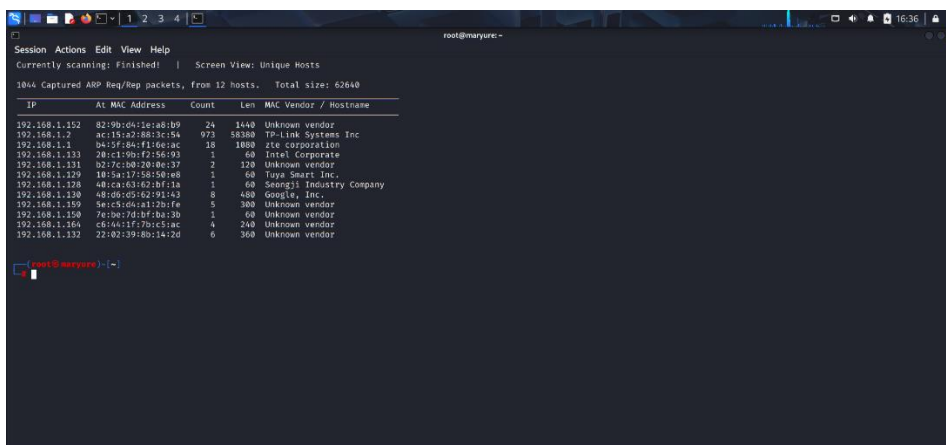
Fase 1 - Reconocimiento y mapeo de red. Escaneamos todos los dispositivos dentro de la red. Para ello, se utilizaron varios comandos con resultados similares (**arp-scan**, **netdiscover**, **nmap**). Sin embargo, **nmap** sigue llevando ventaja, ya que, nos muestra un mapeo más detallado de todo lo que se encuentra conectado a nuestra red, tal como se ilustra en la imagen 3

a. Con **arp-scan**



```
root@maryure:~# arp-scan -l
Interface: eth0, type: EN10MB, MAC: 08:00:27:ff:a1:76, IPv4: 192.168.1.165
Starting arp-scan 1.10.0 with 256 hosts (https://github.com/royhills/arp-scan)
192.168.1.12 08:00:27:ff:a1:76 TP-Link Corporation Limited
192.168.1.11 0a:15:a2:80:3c:54 zte corporation
192.168.1.131 20:c1:50:f2:56:93 Intel Corporate
192.168.1.152 82:9b:d4:3e:a8:b9 (unknown: locally administered)
192.168.1.133 02:7c:10:20:0e:37 (unknown: locally administered)
192.168.1.159 5e:13:04:a1:2b:fe (unknown: locally administered)
192.168.1.128 40:ca:63:b2:b7:1a Seegzi Industry Company
192.168.1.120 48:06:05:02:92:a3 Google, Inc.
192.168.1.129 10:5a:17:58:50:e8 Tuya Smart Inc.
192.168.1.134 7a:24:66:44:a9:1b (unknown: locally administered)
192.168.1.164 c5:6a:1f:7b:c5:ac (unknown: locally administered)
11 packets received by filter, 0 packets dropped by kernel
Ending arp-scan 1.10.0: 256 hosts scanned in 2.052 seconds (124.76 hosts/sec), 11 responded
```

b. Con **netdiscover**



```
root@maryure:~# netdiscover
Session Actions Edit View Help
Currently scanning: Finished! | Screen View: Unique Hosts
1044 Captured ARP Req/Rep packets, from 12 hosts. Total size: 62640

IP            At MAC Address  Count  Len  MAC Vendor / Hostname
-----
192.168.1.152  82:9b:d4:3e:a8:b9  24    1440  Unknown vendor
192.168.1.12  ac:15:a2:80:3c:54  978    58800  TP-Link Systems, Inc.
192.168.1.1  0a:15:a2:80:3c:54  10    1000  zte corporation
192.168.1.133  20:c1:50:f2:56:93  1    60  Intel Corporate
192.168.1.131  02:7c:10:20:0e:37  2    120  Unknown vendor
192.168.1.129  10:5a:17:58:50:e8  1    60  Tuya Smart Inc.
192.168.1.128  40:ca:63:b2:b7:1a  1    60  Seegzi Industry Company
192.168.1.120  48:06:05:02:92:a3  1    480  Google, Inc.
192.168.1.159  5e:13:04:a1:2b:fe  5    300  Unknown vendor
192.168.1.158  7a:24:66:44:a9:1b  1    60  Unknown vendor
192.168.1.164  c5:6a:1f:7b:c5:ac  4    240  Unknown vendor
192.168.1.132  22:02:39:78:0a:14:20  6    360  Unknown vendor
```

c. Con **nmap**

```

root@moryue:-
Session Actions Edit View Help
Starting Nmap 7.95 ( https://nmap.org ) at 2025-10-04 16:41 CEST

root@moryue:~# nmap -sS -v -O 192.168.1.0/24
Starting Nmap 7.95 ( https://nmap.org ) at 2025-10-04 16:41 CEST
Nmap scan report for 192.168.1.1 (192.168.1.1)
Host is up (0.0049s latency).
Not shown: 996 closed tcp ports (reset)
PORT      STATE    SERVICE      VERSION
22/tcp    filtered ssh
53/tcp    open     domain       Actiontec router dnssd
80/tcp    open     Http         ZTE web server 1.0 ZTE corp 2015.
sslv2tcp  open     sslv2        ZTE web server 1.0 ZTE corp 2015.
2 services unrecognized despite returning data. If you know the service/version, please submit the following fingerprints at https://nmap.org/cgi-bin/submit.cgi?new-service :
--
NEXT SERVICE FINGERPRINT (SUBMIT INDIVIDUALLY)
SF:PortBt-TCPVz_65537>no10/A/TIME=6R51310AM/v&d0_64-pc-linux-gm&r/G&tErf
SF:Request_340f..HTTP/1.1.QxZ0208/v20bK/vPnServer:v20bTf/v20web/v20server/v
SF:x201.vx/v20bTf/v20corp/v20b15/vPnAccept-Ranges:v20bytes/vPnConnect1
SF:n-vx/v2close/vXm-Fram-Options:v205AMORIG/vInCache-Control:v20bnc
SF:cache,no-store/vNContent-Type:v20b153/vr/vNSet-Cookie:v20ESID=v9a3b
SF:F75a222657ec3e387F730495995885d7Cca3b0bdload4135b7615sfcc/v20PATHE/v
SF:v20mtidrv/vNset-Cookie:v20TESTCDIUSUPPRT/vx20PTH/vXcm/tcp
SF:Omly/vNContent-Type-Options:v20nosniff/vX-XSS-Protection:v201/vx
SF:20mode-block/vNContent-Security-Policy:v20Frame-ancestors/v20 self/vX
SF:20data/vNContent-Type:v20text/html/v20charset=utf-8/vNvNContentDPT
SF:F/v20HTML/v20PUBLIC/v20"/>NDC/BTD/v20HTML/v204_v01/v20Transitional//
SF:EMY/v20http://www.w3.org/TR/html4/transitional/dtd/>vNhtml/v20x
SF:html/http://www.w3.org/1999/xhtml/vNhead/vNmeta/v20http-equiv/v
SF:Content-Type=/vX/v20Content-Type=text/html/v20charset=utf-8/vx20/v20
SF:v20http-equiv/X-UA-Compatible/v20content/Vf-edge/vNnnet/v20na
SF:v20font-detection/v20content/vXelephong-wg_email_rpg_address/mo/v
SF:vNcLink/v20rel=vShortcut/v20com/vx20href/v/img/f7xr(HTTPptions=5
SF:E2/HTA/v1.vx20408/v20ba5v20Reqest/vPnServer:v20bTf/v20web/v20serv
SF:x201.vx/v20bTf/v20corp/v20b15/vPnAccept-Ranges:v20bytes/vPnConnec1
SF:n-vx/v2close/vXm-Fram-Options:v205AMORIG/vInCache-Control-Type:v20bT
SF:text/html/v20charset-iso-8859-9/vr/vNContent-Type-Options:v20nosniff/vr
SF:n-xss-protection/v201.vx20mode-block/vNContent-Security-Policy/v20
SF:Frame-ancestors/v20 self/v20data/vNCache-Control:v20no-cache,no-sit
```

[illegible]

d. Se identifican servicios con puertos abiertos, se muestran a continuación.

[illegible]

Fase 2 – Análisis y tráfico de paquetes. Escuchamos y capturamos todos los paquetes a través del comando **tcdump**.

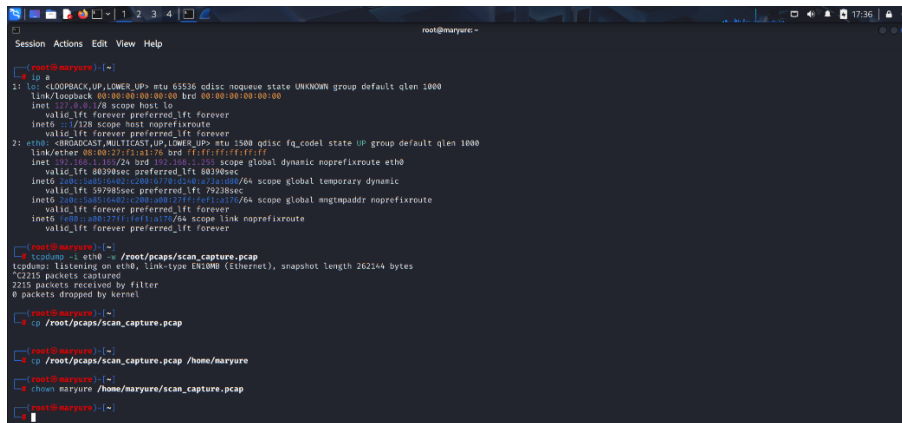
- a. Creamos la carpeta: pcaps

```
(root@maryure)-[~]
```

```
# mkdir pcaps
```

- b. Ejecutamos la siguiente instrucción

```
sudo tcpdump -i eth0 -w /root/pcaps/scan_capture.pcap
```



```
root@maryure ~# ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host noprefixroute
        valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 08:00:27:12:01:76 brd ff:ff:ff:ff:ff:ff
    inet 192.168.1.105/24 brd 192.168.1.255 scope global dynamic noprefixroute eth0
        valid_lft 86398sec preferred_lft 86398sec
    inet6 fe80::a05:1002:c009:9224%eth0/64 scope global temporary dynamic
        valid_lft 597985sec preferred_lft 79238sec
    inet6 2001::a05:1002:c009:9224%eth0/64 scope global mngtaddr noprefixroute
    inet6 fe80::a05:1002:c009:9224%eth0/64 scope link noprefixroute
        valid_lft forever preferred_lft forever

root@maryure ~# sudo tcpdump -i eth0 -w /root/pcaps/scan_capture.pcap
tcpdump: listening on eth0, Link-type EN10MB (Ethernet), snapshot length 262144 bytes
^C2215 packets captured
2215 packets received by filter
0 packets dropped by kernel

root@maryure ~# cp /root/pcaps/scan_capture.pcap

root@maryure ~# cp /root/pcaps/scan_capture.pcap /home/maryure

root@maryure ~# chown maryure /home/maryure/scan_capture.pcap

root@maryure ~#
```

- c. a continuación, copiamos el fichero **scan_capture.pcap** en maryure

```
(root@maryure)-[~]
```

```
# cp /root/pcaps/scan_capture.pcap /home/maryure
```

- d. Cambiamos el dueño del fichero para que pertenezca a maryure

```
(root@maryure)-[~]
```

```
# chown maryure /home/maryure/scan_capture.pcap
```

- e. Abrimos **Wireshark** desde **Kali** y exploramos el tráfico de la red tanto líneas en rojo como posibles anomalías, así como datos de navegación.

Wireshark capture of a TLS handshake. The packet list shows a SYN, Seq=0, Win=64240, Len=0, MSS=1460, SACK_PERM, TSval=3588343202, TSecr=0. The packet details show the TLSv1.3 Record Layer, Handshake Protocol: Client Hello. The packet bytes show the TLSv1.3 Client Hello structure, including the Version (3.1), Random, Session ID, and Supported Versions.

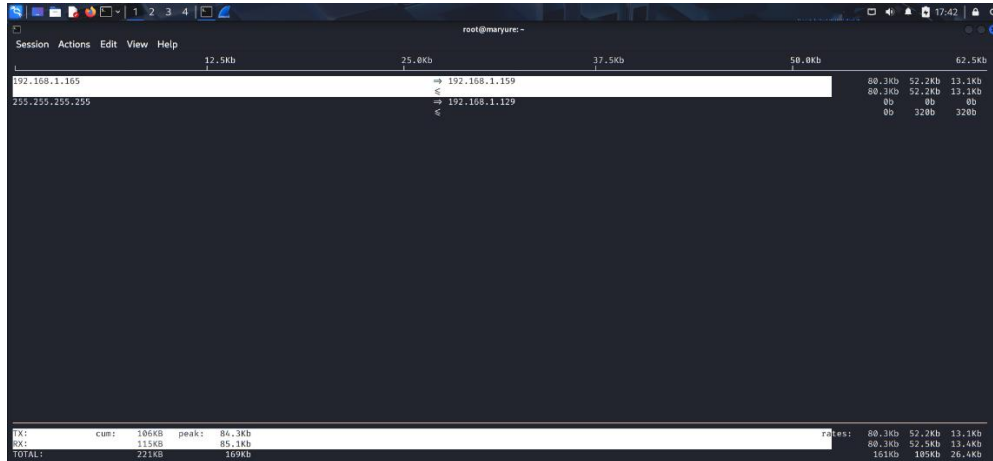
Wireshark capture of an NTP packet. The packet list shows an NTP Version 4, client packet. The packet details show the NTP structure, including the Mode (client), Version (4), and the Timestamp. The packet bytes show the NTP structure, including the Mode, Version, and the Timestamp.

Wireshark capture of an NTP packet. The packet list shows an NTP Version 4, client packet. The packet details show the NTP structure, including the Mode (client), Version (4), and the Timestamp. The packet bytes show the NTP structure, including the Mode, Version, and the Timestamp.

- f. Monitoreamos con **iftop**, ejecutando la siguiente instrucción:

```
(root@maryure)-[~]
```

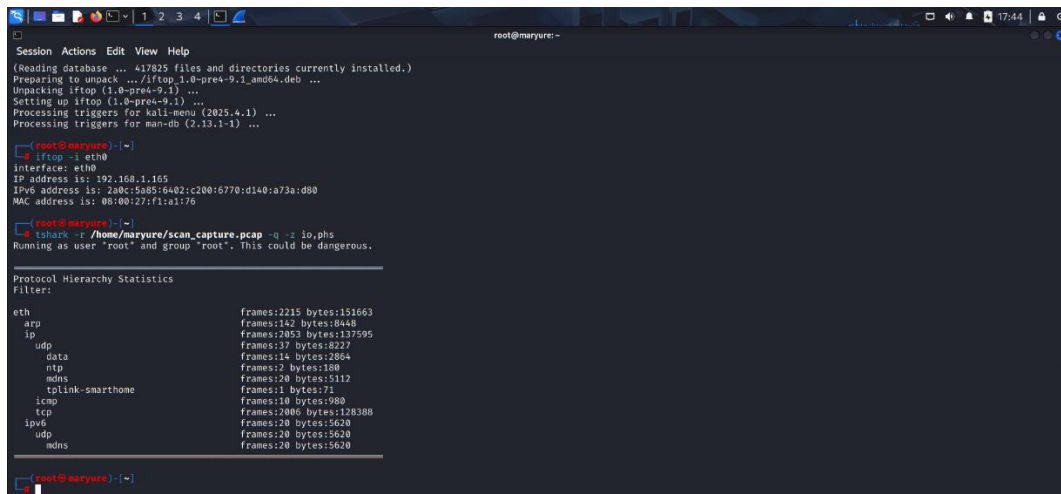
```
# iftop -i eth0
```



- g. Analizamos lo capturado

```
(root@maryure)-[~]
```

```
# tshark -r /home/maryure/scan_capture.pcap -q -z io,phs
```



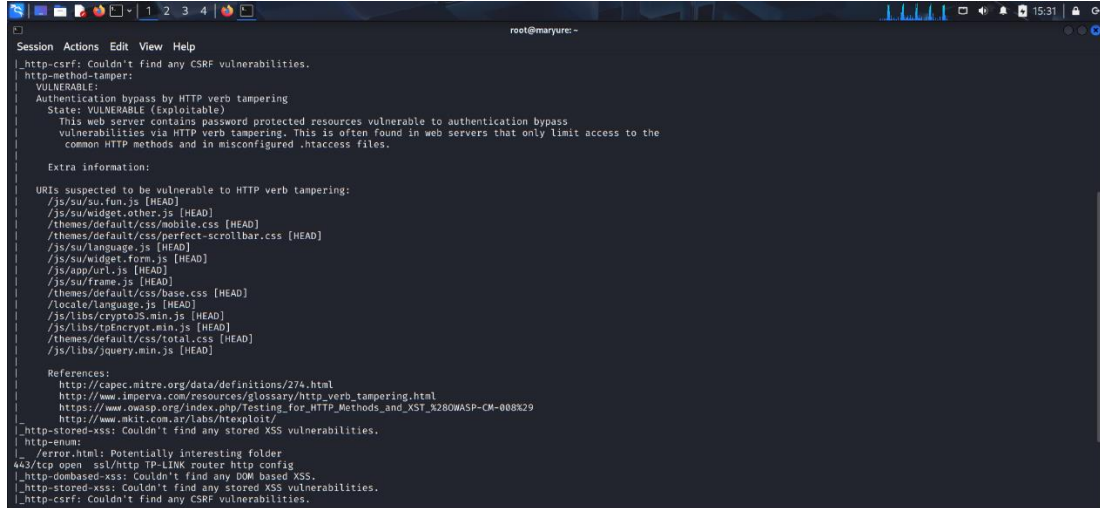
Fase 3 – Enumeración de servicios y pruebas seguras. Verificar configuraciones visibles (vulnerabilidades de servicio sin explotar)

- a. Se ejecuta la siguiente instrucción para mapear a un dispositivo:

—(root@maryure)-[~]

└─# nmap -sV --script=vuln 192.168.1.2

- b. Se encuentran vulnerabilidades en el puerto 80



```
Session Actions Edit View Help
|_ http-csrf: Couldn't find any CSRF vulnerabilities.
|_ http-method-tamper:
|   VULNERABLE:
|     Authentication bypass by HTTP verb tampering
|     State: VULNERABLE (exploitable)
|     This web server contains password protected resources vulnerable to authentication bypass
|     vulnerabilities via HTTP verb tampering. This is often found in web servers that only limit access to the
|     common HTTP methods and in misconfigured .htaccess files.
|
|     Extra information:
|
|     URIs suspected to be vulnerable to HTTP verb tampering:
|     /js/su/su.fun.js [HEAD]
|     /js/su/widget.other.js [HEAD]
|     /themes/default/css/mobile.css [HEAD]
|     /themes/default/css/perfect-scrollbar.css [HEAD]
|     /js/su/language.js [HEAD]
|     /js/su/widget.form.js [HEAD]
|     /js/app/url.js [HEAD]
|     /js/su/frame.js [HEAD]
|     /themes/default/css/base.css [HEAD]
|     /locale/language.js [HEAD]
|     /js/libs/cryptoJS.min.js [HEAD]
|     /js/libs/tpEncrypt.min.js [HEAD]
|     /themes/default/css/total.css [HEAD]
|     /js/libs/jquery.min.js [HEAD]
|
|     References:
|     http://cve.mitre.org/data/definitions/274.html
|     http://www.immware.com/resources/glossary/http-verb-tampering.html
|     https://www.owasp.org/index.php/Testing_for_HTTP_Methods_and_XST_3280WASP-CM-008929
|     http://www.mkrit.com.ar/labs/htexploit/
|_ http-stored-xss: Couldn't find any stored XSS vulnerabilities.
|_ http-enum:
|   /error.html: Potentially interesting folder
|_ 443/tcp open  ssl/http TP-LINK router http config
|_ http-dombased-xss: Couldn't find any DOM based XSS.
|_ http-stored-xss: Couldn't find any stored XSS vulnerabilities.
|_ http-csrf: Couldn't find any CSRF vulnerabilities.
```

- c. Analizamos con **curl** la web que nos aparecía con vulnerabilidades. Ejecutamos la siguiente instrucción:

curl http://192.168.1.2:80/js/su/su.fun.js

Obtuvimos:

—(root@maryure)-[~]

└─# curl -v http://192.168.1.2:80/js/su/su.fun.js

```
* Trying 192.168.1.2:80...
* Connected to 192.168.1.2 (192.168.1.2) port 80
* using HTTP/1.x
> GET /js/su/su.fun.js HTTP/1.1
> Host: 192.168.1.2
> User-Agent: curl/8.15.0
> Accept: */*
>
* Request completely sent off
< HTTP/1.1 401 Unauthorized
```

< Content-Type: text/html;charset=UTF-8

< Content-Length: 0

< Connection: close

< Cache-control: no-cache

<

* shutting down connection #0

Con el 401 comprobamos que no podemos acceder a ella, por lo tanto, no se observa una vulnerabilidad de alto impacto.

- d. Analizamos con **nikto** para ver más detalles sobre las vulnerabilidades. Ejecutamos las siguientes instrucciones:

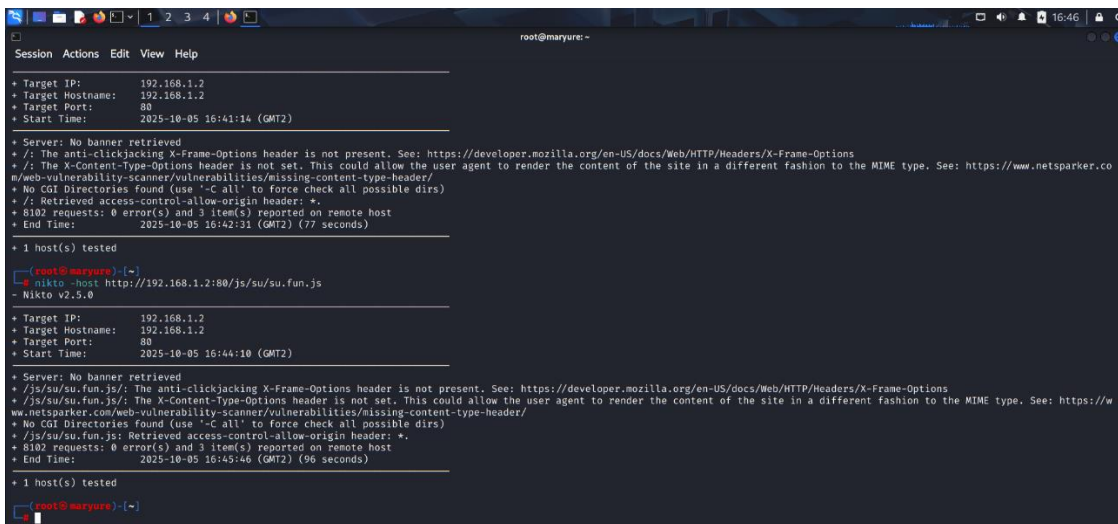
```
(root@maryure)-[~]
```

```
# nikto -host http://192.168.1.2:80
```

```
(root@maryure)-[~]
```

```
# nikto -host http://192.168.1.2:80/js/su/su.fun.js
```

Obtuvimos detalles de la vulnerabilidad encontrada con el **nmap** anterior. Se describen detalles mal hechos en la página, sin embargo, no representa un riesgo de mayor importancia.

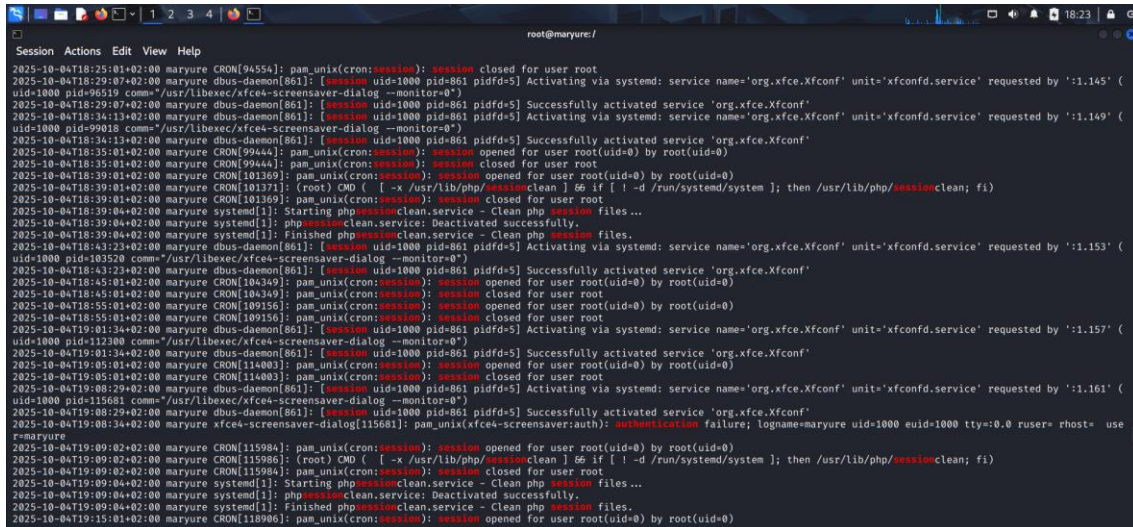


```
root@maryure: ~  
Session Actions Edit View Help  
+ Target IP: 192.168.1.2  
+ Target Hostname: 192.168.1.2  
+ Target Port: 80  
+ Start Time: 2025-10-05 16:41:14 (GMT2)  
  
+ Server: No banner retrieved  
+ /: The anti-clickjacking X-Frame-Options header is not present. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Frame-Options  
+ /: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME type. See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/missing-content-type-header/  
+ No CGI Directories found (use '-C all' to force check all possible dirs)  
+ /: Retrieved access-control-allow-origin header: *.  
+ 8102 requests: 0 error(s) and 3 item(s) reported on remote host  
+ End Time: 2025-10-05 16:42:31 (GMT2) (77 seconds)  
  
+ 1 host(s) tested  
  
(root@maryure)-[~]  
# nikto -host http://192.168.1.2:80/js/su/su.fun.js  
- Nikto v2.5.0  
  
+ Target IP: 192.168.1.2  
+ Target Hostname: 192.168.1.2  
+ Target Port: 80  
+ Start Time: 2025-10-05 16:44:10 (GMT2)  
  
+ Server: No banner retrieved  
+ /js/su/su.fun.js/: The anti-clickjacking X-Frame-Options header is not present. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Frame-Options  
+ /js/su/su.fun.js/: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME type. See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/missing-content-type-header/  
+ No CGI Directories found (use '-C all' to force check all possible dirs)  
+ /js/su/su.fun.js: Retrieved access-control-allow-origin header: *.  
+ 8102 requests: 0 error(s) and 3 item(s) reported on remote host  
+ End Time: 2025-10-05 16:45:46 (GMT2) (96 seconds)  
  
+ 1 host(s) tested  
  
(root@maryure)-[~]
```

FASE 4 — Análisis de logs y forense básico. Revisar logs del sistema/servicios para identificar actividad sospechosa.

- a. Revisamos los logs con **journalctl** para identificar los registros que existen. Ejecutamos la siguiente instrucción que mostrará todo lo relacionado con autenticaciones, no solo **ssh**

journalctl -o short-iso | grep -Ei "authentication|sudo|sshd|session"



- b. Generamos el archivo **csv** con los eventos.

**journalctl -o short-iso | grep -Ei "authentication|sudo|sshd|session" | **

```
awk -F' ' {  
  
    hora=$1;  
  
    if ($0 ~ /Failed/) evento="Failed_Login";  
  
    else if ($0 ~ /Accepted/) evento="Successful_Login";  
  
    else if ($0 ~ /sudo/) evento="Sudo_Command";  
  
    else if ($0 ~ /session opened/) evento="Session_Opened";  
  
    else if ($0 ~ /session closed/) evento="Session_Closed";  
  
    else evento="Other";  
  
    match($0, /from ([0-9]+\.[0-9]+\.[0-9]+\.[0-9]+)/, ip);  
  
    ip_origen=(ip[1]!="")?ip[1]:"Localhost";  
  
    descripcion=$0;  
  
    printf "%s,%s,%s,\"%s\\\"\\n", evento, hora, ip_origen, descripcion;  
  
} ' > /root/timeline.csv
```

- c. Revisamos el archivo. Ejecutamos con **cat**. Hay dos maneras de verlo, uno más general, ejecutando la siguiente instrucción:

cat /root/timeline.csv | head


```
root@maryure:/  
Session Actions Edit View Help  
root@maryure:~# cat /root/timeline.csv  
Other,2025-10-04T14:40:51+02:00,Localhost,"2025-10-04T14:40:51+02:00 maryure systemd[1]: Created slice user.slice - User and Session Slice."  
Other,2025-10-04T14:40:53+02:00,Localhost,"2025-10-04T14:40:53+02:00 maryure systemd[1]: Started phpsessionclean.timer - Clean PHP session files every 30 mins."  
Other,2025-10-04T14:40:53+02:00,Localhost,"2025-10-04T14:40:53+02:00 maryure systemd[1]: Listening on sshd-unix-local.socket - OpenSSH Server Socket (systemd-ssh-generator, AF_UNIX Local)."  
Other,2025-10-04T14:40:53+02:00,Localhost,"2025-10-04T14:40:53+02:00 maryure systemd[1]: Listening on sshd-vsock.socket - OpenSSH Server Socket (systemd-ssh-generator, AF_VSOCK)."  
Other,2025-10-04T14:40:53+02:00,Localhost,"2025-10-04T14:40:53+02:00 maryure virtualbox-guest-utils[634]: 12:40:53.482302 main Session type is: VBGHDISPLAYSERVERTYPE_NONE"  
Other,2025-10-04T14:40:53+02:00,Localhost,"2025-10-04T14:40:53+02:00 maryure kernel: 12:40:53.482302 main Session type is: VBGHDISPLAYSERVERTYPE_NONE"  
Other,2025-10-04T14:40:53+02:00,Localhost,"2025-10-04T14:40:53+02:00 maryure systemd[1]: Starting systemd-user-sessions.service - Permit User Sessions..."  
Other,2025-10-04T14:40:53+02:00,Localhost,"2025-10-04T14:40:53+02:00 maryure systemd[1]: Finished systemd-user-sessions.service - Permit User Sessions."  
Session_Opened,2025-10-04T14:40:55+02:00,Localhost,"2025-10-04T14:40:55+02:00 maryure lightdm[700]: pam_unix(lightdm-greeter:session): session opened for user lightdm(uid=124) by (uid=0)"  
Other,2025-10-04T14:40:55+02:00,Localhost,"2025-10-04T14:40:55+02:00 maryure systemd-logind[583]: New session c1 of user lightdm."  
root@maryure:~# column -t -s, /root/timeline.csv  
Other      2025-10-04T14:40:51+02:00  Localhost  "2025-10-04T14:40:51+02:00 maryure systemd[1]: Created slice user.slice - User and Session Slice."  
  
Other      2025-10-04T14:40:53+02:00  Localhost  "2025-10-04T14:40:53+02:00 maryure systemd[1]: Started phpsessionclean.timer - Clean PHP session files every 30 mins."  
  
Other      2025-10-04T14:40:53+02:00  Localhost  "2025-10-04T14:40:53+02:00 maryure systemd[1]: Listening on sshd-unix-local.socket - OpenSSH Server Socket (systemd-ssh-generator  
AF_UNIX Local)."  
  
Other      2025-10-04T14:40:53+02:00  Localhost  "2025-10-04T14:40:53+02:00 maryure systemd[1]: Listening on sshd-vsock.socket - OpenSSH Server Socket (systemd-ssh-generator  
AF_VSOCK)."  
  
Other      2025-10-04T14:40:53+02:00  Localhost  "2025-10-04T14:40:53+02:00 maryure virtualbox-guest-utils[634]: 12:40:53.482302 main Session type is: VBGHDISPLAYSERVERTYPE_NONE"  
  
Other      2025-10-04T14:40:53+02:00  Localhost  "2025-10-04T14:40:53+02:00 maryure kernel: 12:40:53.482302 main Session type is: VBGHDISPLAYSERVERTYPE_NONE"  
  
Other      2025-10-04T14:40:53+02:00  Localhost  "2025-10-04T14:40:53+02:00 maryure systemd[1]: Starting systemd-user-sessions.service - Permit User Sessions..."  
  
Other      2025-10-04T14:40:53+02:00  Localhost  "2025-10-04T14:40:53+02:00 maryure systemd[1]: Finished systemd-user-sessions.service - Permit User Sessions."
```

Y otra manera, más detallada con columnas, de la siguiente manera:

```
(root@maryure)-[/]  
# column -t -s, /root/timeline.csv
```

```
root@maryure:/  
Session Actions Edit View Help  
root@maryure:~# column -t -s, /root/timeline.csv  
Other      2025-10-04T14:40:51+02:00  Localhost  "2025-10-04T14:40:51+02:00 maryure systemd[1]: Created slice user.slice - User and Session Slice."  
  
Other      2025-10-04T14:40:53+02:00  Localhost  "2025-10-04T14:40:53+02:00 maryure systemd[1]: Started phpsessionclean.timer - Clean PHP session files every 30 mins."  
  
Other      2025-10-04T14:40:53+02:00  Localhost  "2025-10-04T14:40:53+02:00 maryure systemd[1]: Listening on sshd-unix-local.socket - OpenSSH Server Socket (systemd-ssh-generator  
AF_UNIX Local)."  
  
Other      2025-10-04T14:40:53+02:00  Localhost  "2025-10-04T14:40:53+02:00 maryure systemd[1]: Listening on sshd-vsock.socket - OpenSSH Server Socket (systemd-ssh-generator  
AF_VSOCK)."  
  
Other      2025-10-04T14:40:53+02:00  Localhost  "2025-10-04T14:40:53+02:00 maryure virtualbox-guest-utils[634]: 12:40:53.482302 main Session type is: VBGHDISPLAYSERVERTYPE_NONE"  
  
Other      2025-10-04T14:40:53+02:00  Localhost  "2025-10-04T14:40:53+02:00 maryure kernel: 12:40:53.482302 main Session type is: VBGHDISPLAYSERVERTYPE_NONE"  
  
Other      2025-10-04T14:40:53+02:00  Localhost  "2025-10-04T14:40:53+02:00 maryure systemd[1]: Starting systemd-user-sessions.service - Permit User Sessions..."  
  
Other      2025-10-04T14:40:53+02:00  Localhost  "2025-10-04T14:40:53+02:00 maryure systemd[1]: Finished systemd-user-sessions.service - Permit User Sessions."  
  
Session_Opened 2025-10-04T14:40:55+02:00  Localhost  "2025-10-04T14:40:55+02:00 maryure lightdm[700]: pam_unix(lightdm-greeter:session): session opened for user lightdm(uid=124) by (uid=0)"  
  
Other      2025-10-04T14:40:55+02:00  Localhost  "2025-10-04T14:40:55+02:00 maryure systemd-logind[583]: New session c1 of user lightdm."  
  
Session_Opened 2025-10-04T14:40:55+02:00  Localhost  "2025-10-04T14:40:55+02:00 maryure (systemd)[707]: pam_unix(systemd-user:session): session opened for user lightdm(uid=124) by lightdm  
(uid=0)"  
  
Other      2025-10-04T14:40:55+02:00  Localhost  "2025-10-04T14:40:55+02:00 maryure systemd-logind[583]: New session 1 of user lightdm."  
  
Other      2025-10-04T14:40:55+02:00  Localhost  "2025-10-04T14:40:55+02:00 maryure systemd[707]: Created slice session.slice - User Core Session Slice."
```

FASE 5 — Gestión de usuarios y permisos. Demostrar creación de cuentas, grupos y buenas prácticas y auditar permisos.

a. Crear grupos y usuarios

```
(root@maryure)-[~]  
# # crea grupos (no falla si ya existe, gracias a -f)  
sudo groupadd -f subequipo1  
sudo groupadd -f subequipo2
```

```
sudo groupadd -f subequipo3
```

```
# crea usuario con directorio home, shell bash, y grupo primario
```

```
sudo useradd -m -s /bin/bash -g subequipo1 -c "Usuario subequipo1" usuario1
```

```
sudo useradd -m -s /bin/bash -g subequipo2 -c "Usuario subequipo2" usuario2
```

```
sudo useradd -m -s /bin/bash -g subequipo3 -c "Usuario subequipo3" usuario3
```

```
# asignar contraseñas temporales (cambiar 'TempPass123!' por contraseñas seguras)
```

```
echo 'usuario1:TempPass123!' | sudo chpasswd
```

```
echo 'usuario2:TempPass123!' | sudo chpasswd
```

```
echo 'usuario3:TempPass123!' | sudo chpasswd
```

```
# forzar cambio de contraseña en primer login
```

```
sudo chage -d 0 usuario1
```

```
sudo chage -d 0 usuario2
```

```
sudo chage -d 0 usuario3
```

- b. Crear directorio para cada subequipo, hacer root dueño + grupo = subequipoX, permisos rwx para owner y group, ninguno para otros, y **setgid** para que los ficheros nuevos hereden el grupo:

```
sudo mkdir -p /srv/subequipo1
```

```
sudo mkdir -p /srv/subequipo2
```

```
sudo mkdir -p /srv/subequipo3
```

```
# owner=root, group=subequipoX
```

```
sudo chown root:subequipo1 /srv/subequipo1
```

```
sudo chown root:subequipo2 /srv/subequipo2
```

```
sudo chown root:subequipo3 /srv/subequipo3
```

```
# permiso: drwxrws--- -> setgid (2) + 770
```

```
sudo chmod 2770 /srv/subequipo1
```

```
sudo chmod 2770 /srv/subequipo2
```

```
sudo chmod 2770 /srv/subequipo3
```

Explicación corta: 2770 → 2 = setgid (archivos nuevos heredan grupo), 7 owner (rwx), 7 group (rwx), 0 others (---). Así sólo miembros del grupo pueden entrar/crear.

- c. Añadir usuarios a grupos secundarios (si hace falta). Si quieres añadir un usuario existente a un grupo como secundario:

```
usermod -aG subequipo1 usuario1
```

El -aG añade a la lista de grupos sin quitar otros.

- d. Verificar usuarios y sus grupos

```
(root@maryure)-[~]
# id usuario1

uid=1001(usuario1) gid=1001(subequipo1) groups=1001(subequipo1)
```

- e. Verificar permisos del directorio.

```
(root@maryure)-[~]
# ls -ld /srv/subequipo1

drwxrws--- 2 root subequipo1 4096 Oct  5 18:58 /srv/subequipo1
```

- f. Si quieres ver ACLs

```
(root@maryure)-[~]
# getfacl /srv/subequipo1

getfacl: Removing leading '/' from absolute path names
# file: srv/subequipo1
# owner: root
# group: subequipo1
# flags: -s-
user::rwx
group::rwx
other::---
```

- g. Auditoria

```
(root@maryure)-[~]
# # verificar cada usuario
```

id usuario1

id usuario2

id usuario3

verificar permisos de los directorios

ls -ld /srv/subequipo1 /srv/subequipo2 /srv/subequipo3

listar miembros del grupo

getent group subequipo1

getent group subequipo2

getent group subequipo3

(opcional) ver ACLs recursivas

getfacl -R /srv/subequipo1

uid=1001(usuario1) gid=1001(subequipo1) groups=1001(subequipo1)

uid=1002(usuario2) gid=1002(subequipo2) groups=1002(subequipo2)

uid=1003(usuario3) gid=1003(subequipo3) groups=1003(subequipo3)

drwxrws--- 2 root subequipo1 4096 Oct 5 18:58 /srv/subequipo1

drwxrws--- 2 root subequipo2 4096 Oct 5 18:58 /srv/subequipo2

drwxrws--- 2 root subequipo3 4096 Oct 5 18:58 /srv/subequipo3

subequipo1:x:1001:usuario1

subequipo2:x:1002:

subequipo3:x:1003:

getfacl: Removing leading '/' from absolute path names

file: srv/subequipo1

owner: root

group: subequipo1

```
# flags: -s-  
user::rwx  
group::rwx  
other::---
```

Recurso adicional: Script completo (automatizable).Copia y pega este script, edita usuarios/nombres y ejecútalo como root:

```
#!/bin/bash  
  
set -e  
  
declare -A TEAMS=( ["subequipo1"]="usuario1" ["subequipo2"]="usuario2"  
["subequipo3"]="usuario3" )  
  
for team in "${!TEAMS[@]}"; do  
    user=${TEAMS[$team]}  
  
    echo "=== Configurando $team / $user ==="  
  
    sudo groupadd -f "$team"  
  
    if ! id "$user" &>/dev/null; then  
        sudo useradd -m -s /bin/bash -g "$team" -c "Usuario $user del  
$team" "$user"  
  
        echo "$user:TempPass123!" | sudo chpasswd  
        sudo chage -d 0 "$user"  
  
    else  
        echo "Usuario $user ya existe"  
  
    fi  
  
    sudo mkdir -p "/srv/$team"  
    sudo chown root:"$team" "/srv/$team"  
    sudo chmod 2770 "/srv/$team"  
    echo "Directorio /srv/$team listo"  
  
done
```



```

root@maryure: ~
Session Actions Edit View Help

root@maryure:~# # verificar cada usuario
id usuario1
id usuario2
id usuario3

# verificar permisos de los directorios
ls -ld /srv/subequipo1 /srv/subequipo2 /srv/subequipo3

# listar miembros del grupo
getent group subequipo1
getent group subequipo2
getent group subequipo3

# (opcional) ver Acls recursivas
getfacl -R /srv/subequipo1
uid=1001(usuario1) gid=1001(subequipo1) groups=1001(subequipo1)
uid=1002(usuario2) gid=1002(subequipo2) groups=1002(subequipo2)
uid=1003(usuario3) gid=1003(subequipo3) groups=1003(subequipo3)
drwxrws--- 2 root subequipo1 4096 Oct 5 18:58 /srv/subequipo1
drwxrws--- 2 root subequipo2 4096 Oct 5 18:58 /srv/subequipo2
drwxrws--- 2 root subequipo3 4096 Oct 5 18:58 /srv/subequipo3
subequipo1:x:1001:usuario1
subequipo2:x:1002:
subequipo3:x:1003:
getfacl: Removing leading '/' from absolute path names
# file: srv/subequipo1
# owner: root
# group: subequipo1
# flags: -s-
user::rwx
group::rwx
other::---

root@maryure:~#

```

FASE 6 — Endurecimiento y medidas de protección (firewall, IDS, mitigaciones)

- Creamos la tabla, con la cadena y las reglas

```

root@maryure:~# # nft list ruleset
table inet filtro {
    chain input {
        type filter hook input priority filter; policy drop;
        iif "lo" accept
        iif "lo" accept
        ct state { established, related } accept
    }
}

```

- Desde otra máquina accedemos a la máquina de prueba donde están configuradas las reglas y obtenemos este mapeo mediante nmap.

```
root@maryure:~# nft list ruleset
table inet filtro {
  chain input {
    type filter hook input priority filter; policy drop;
    iif "lo" accept
    iif "lo" accept
    ct state { established, related } accept
  }
}

root@maryure:~#

maryure@kawi:~$ nmap -Pn 192.168.1.165
Starting Nmap 7.92 ( https://nmap.org ) at 2025-10-05 21:15 CEST
Stats: 0:01:04 elapsed; 0 hosts completed (1 up), 1 undergoing Connect Scan
Connect Scan Timing: About 25.00% done; ETC: 21:19 (0:02:33 remaining)
Stats: 0:01:05 elapsed; 0 hosts completed (1 up), 1 undergoing Connect Scan
Connect Scan Timing: About 25.50% done; ETC: 21:19 (0:02:32 remaining)

maryure@kawi ~]$ nmap -Pn 192.168.1.165
Starting Nmap 7.92 ( https://nmap.org ) at 2025-10-05 21:16 CEST

maryure@kawi ~]$ nmap 192.168.1.165
Starting Nmap 7.92 ( https://nmap.org ) at 2025-10-05 21:16 CEST
Note: Host seems down. If it is really up, but blocking our ping probes, try -Pn
Nmap done: 1 IP address (0 hosts up) scanned in 3.05 seconds

maryure@kawi ~]$ nmap -Pn 192.168.1.165
Starting Nmap 7.92 ( https://nmap.org ) at 2025-10-05 21:18 CEST
Stats: 0:00:52 elapsed; 0 hosts completed (1 up), 1 undergoing Connect Scan
Connect Scan Timing: About 19.00% done; ETC: 21:22 (0:02:46 remaining)
Stats: 0:00:53 elapsed; 0 hosts completed (1 up), 1 undergoing Connect Scan
Connect Scan Timing: About 19.50% done; ETC: 21:22 (0:02:45 remaining)

maryure@kawi ~]$ ping 192.168.1.165
PING 192.168.1.165 (192.168.1.165) 56(84) bytes of data.
```

En la captura observamos dos máquinas virtuales (**máquina1**, **máquina2**). Al ejecutar **nmap** desde **máquina2**(derecha) hacia **máquina1**, observamos como se ralentiza la comunicación. Interpretamos que esto puede ocurrir debido a que, en primera instancia, **máquina1** tiene varios puertos cerrados.

- c. A continuación, cambiamos una regla y abrimos varios puertos en **máquina1** y repetimos el mapeo desde **máquina2** a **máquina1**. Sin embargo, los puertos aparecen cerrados. Interpretamos que esto puede pasar porque los servicios no estaban activos.

```
root@maryure:~# nft list ruleset
table inet filtro {
  chain input {
    type filter hook input priority filter; policy drop;
    iif "lo" accept
    iif "lo" accept
    ct state { established, related } accept
  }
}

root@maryure:~# nft add rule inet filtro input tcp dport {22,80,443,3128} accept
Error: syntax error, unexpected accept
add rule inet filtro input tcp dport 22 80 443 3128 accept *****

root@maryure:~# nft add rule inet filtro input tcp dport '{22,80,443,3128}' accept

root@maryure:~# nft list ruleset
table inet filtro {
  chain input {
    type filter hook input priority filter; policy drop;
    iif "lo" accept
    iif "lo" accept
    ct state { established, related } accept
    tcp dport { 22, 80, 443, 3128 } accept
  }
}

root@maryure:~# nft list ruleset > /etc/nftables.conf

root@maryure:~# nft list ruleset
table inet filtro {

maryure@maryure:~$ nmap -Pn 192.168.1.165
6 packets transmitted, 6 received, 0% packet loss, time 5009ms
rtt min/avg/max/ndev = 6.339/8.458/11.769/1.665 ms
maryure@kawi ~]$ nmap 192.168.1.165
Starting Nmap 7.92 ( https://nmap.org ) at 2025-10-05 20:22 CEST
Nmap scan report for 192.168.1.165
Host is up (0.0073s latency).
Not shown: 996 filtered tcp ports (no-response)
PORT      STATE SERVICE
22/tcp    closed ssh
80/tcp    closed http
443/tcp   closed https
3128/tcp   closed squid-http

maryure@kawi ~]$ nmap -Pn 192.168.1.165
Starting Nmap 7.92 ( https://nmap.org ) at 2025-10-05 20:31 CEST
Nmap scan report for 192.168.1.165
Host is up (0.0091s latency).
Not shown: 996 filtered tcp ports (no-response)
PORT      STATE SERVICE
22/tcp    closed ssh
80/tcp    closed http
443/tcp   closed https
3128/tcp   closed squid-http

maryure@kawi ~]$ nmap 192.168.1.165
Starting Nmap 7.92 ( https://nmap.org ) at 2025-10-05 20:31 CEST
Nmap scan report for 192.168.1.165
Host is up (0.0091s latency).
Not shown: 996 filtered tcp ports (no-response)
PORT      STATE SERVICE
22/tcp    closed ssh
80/tcp    closed http
443/tcp   closed https
3128/tcp   closed squid-http

maryure@kawi ~]$ ping 192.168.1.165
PING 192.168.1.165 (192.168.1.165) 56(84) bytes of data.
```

- d. Activamos el servicio **ssh** en **máquina1** y repetimos el mapeo anterior desde **máquina2**. Observamos que efectivamente aun cuando la regla nos indica que son puerto abiertos, si el servicio no está arriba, en el mapeo aparecerán cerrados. Tal como se muestra en la imagen abajo, al activar el servicio **ssh** en **máquina1** en **máquina2** mapeo el puerto 22 como abierto.

The image shows two terminal windows. The left window is on 'maryure' (máquina1) and the right window is on 'maryure@kawi' (máquina2).

Left Terminal (maryure):

```
root@maryure:~# nft add rule inet filtro input tcp dport {22,80,443,3128} accept
Error: syntax error, unexpected accept
add rule inet filtro input tcp dport 22 80 443 3128 accept
root@maryure:~# nft add rule inet filtro input tcp dport '{22,80,443,3128}' accept
root@maryure:~# nft list ruleset
table inet filtro {
  chain input {
    type filter hook input priority filter; policy drop;
    iif "lo" accept
    iif "lo" accept
    ct state { established, related } accept
    tcp dport { 22, 80, 443, 3128 } accept
  }
}
root@maryure:~# nft list ruleset > /etc/nftables.conf
root@maryure:~# nft list ruleset
table inet filtro {
  chain input {
    type filter hook input priority filter; policy drop;
    iif "lo" accept
    iif "lo" accept
    ct state { established, related } accept
    tcp dport { 22, 80, 443, 3128 } accept
  }
}
```

Right Terminal (maryure@kawi):

```
Session Actions Edit View Help
Connect Scan Timing: About 19.58% done; ETC: 21:22 (0:02:45 remaining)

[maryure@kawi ~]$ ping 192.168.1.165
PING 192.168.1.165 (192.168.1.165) 56(84) bytes of data.
^C
--- 192.168.1.165 ping statistics ---
345 packets transmitted, 0 received, 100% packet loss, time 352264ms

[maryure@kawi ~]$ ping 192.168.1.165
PING 192.168.1.165 (192.168.1.165) 56(84) bytes of data.
^C
--- 192.168.1.165 ping statistics ---
10 packets transmitted, 0 received, 100% packet loss, time 9240ms

[maryure@kawi ~]$ nmap 192.168.1.165
Starting Nmap 7.92 ( https://nmap.org ) at 2025-10-05 21:26 CEST
Nmap Scan report for 192.168.1.165
Host is up (0.0060s latency).
Not shown: 996 filtered tcp ports (no-response)
PORT      STATE SERVICE
22/tcp    open  ssh
80/tcp    closed http
443/tcp   closed https
3128/tcp  closed squid-http

Nmap done: 1 IP address (1 host up) scanned in 17.45 seconds
[maryure@kawi ~]$
```